

Applied Security-Informed Safety Case Studies

Dr Ayman El Hajjar

CyBOK © Crown Copyright, The National Cyber Security Centre 2026, licensed under the Open Government Licence

<http://www.nationalarchives.gov.uk/doc/open-government-licence/>

The lecture maps to the following CyBOK Knowledge Areas:

Full Coverage:

- Infrastructure Security → Cyber-Physical Systems Security
- Infrastructure Security → Network Security
- Human, Organisational and Regulatory Aspects → Risk Management & Governance

Partly Covered:

- Infrastructure Security → Physical Layer and Telecommunications Security
- Attacks and Defences → Security Operations & Incident Management
- Systems Security → Authentication, Authorisation & Accountability

APPLYING SECURITY-INFORMED SAFETY

MEDICAL IOT CASE STUDY

SMART BUILDING CASE STUDY

6LoWPAN CASE STUDY

COMPARING THE APPLIED CASES

Applying Security-Informed Safety

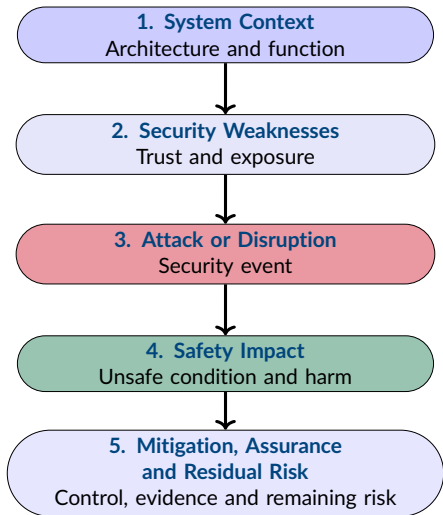
Applied Security-Informed Safety

Uses **security analysis**, **hazard reasoning**, and **safety consequences** together to examine how attacks and disruptions affect real system behaviour.

- Previous lectures introduced security failures, hazards, assurance, wireless threats, safety-critical IoT, and resilience.
- Applied cases bring these concepts together within a **complete system context**.
- The focus is not only on whether an attack succeeds.
- The analysis traces how a security event changes **data**, **communication**, **system behaviour**, and possible **safety outcomes**.

The same security event can have very different safety consequences depending on the system in which it occurs.

A COMMON CASE STUDY ANALYSIS METHOD



- Each case uses the **same analysis sequence**.
- This supports comparison across technologies and operational environments.
- The objective is to identify how security weaknesses create or amplify **safety-relevant behaviour**, while distinguishing direct observation, inference and assumptions.

A case study should connect technical evidence to operational effects, unsafe conditions and appropriate controls.

THREE CATEGORIES OF ATTACK AND DISRUPTION

Infrastructure Attacks and Disruptions

Affect supporting components, services, gateways, access points, brokers, or network availability.

Communication and Protocol Attacks

Exploit wireless links, protocol behaviour, message exchange, association, pairing, or transport mechanisms.

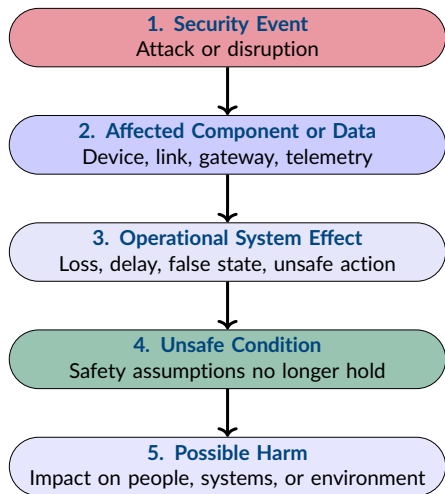
Telemetry and Application-Layer Attacks

Manipulate sensor values, application messages, commands, state, or the interpretation of system data.

- An attack may fall into **more than one category**.
- The category identifies where the security event occurs, not the final safety consequence.
- Safety analysis must trace how the event affects **system behaviour**.

The same safety hazard may be reached through attacks at different layers of the system.

TRACING SECURITY EVENTS TO SAFETY HARM



- The **security event** identifies what happened technically.
- The **operational effect** explains how the system changes as a result.
- The **unsafe condition** identifies where expected safety assumptions are violated.
- Possible harm should be linked to the system context rather than assumed from the attack alone.

Security-informed safety asks how a technical event propagates through system behaviour before harm becomes possible.

Medical IoT Case Study

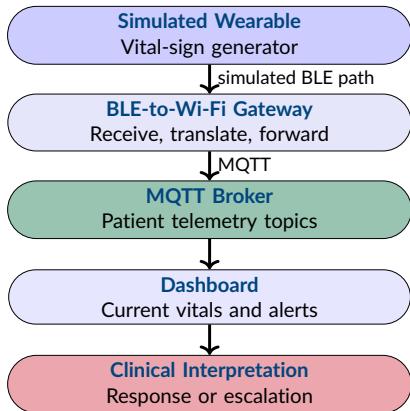
SISEN Scenario Context

The Medical IoT scenario simulates a wearable patient monitoring system in which generated vital-sign data is forwarded through a **BLE-to-Wi-Fi gateway**, published over MQTT and displayed on a monitoring dashboard.

- The scenario represents patient telemetry such as **heart rate**, **SpO₂** and **blood pressure**.
- The current SISEN implementation simulates the BLE communication path rather than capturing over-the-air Bluetooth traffic.
- The gateway log, MQTT packets and dashboard state provide the main sources of evidence.
- Safety relevance comes from whether the displayed patient state remains **authentic**, **current**, **complete** and **clinically plausible**.

A patient may be physically deteriorating while the monitoring system continues

MEDICAL IOT SYSTEM ARCHITECTURE



- The gateway is the key **translation point** between wearable telemetry and IP-based monitoring.
- MQTT topics such as patient vital-sign streams expose structure, identifiers and values.
- The dashboard represents the patient through received telemetry rather than direct observation.
- Evidence comes from **gateway logs**, **MQTT captures**, subscriptions and dashboard changes.

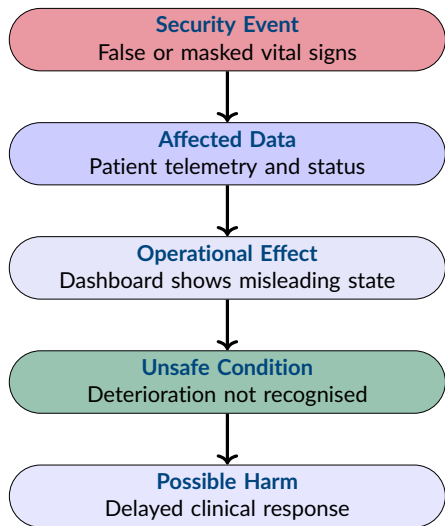
The dashboard may be technically consistent with the received data while still being clinically misleading.

MEDICAL IoT ACTIVITIES IMPLEMENTED IN SISEN

- **Gateway log observation** shows whether wearable telemetry reaches the BLE-to-Wi-Fi gateway and is forwarded.
- **MQTT topic observation** exposes the topic hierarchy, payload structure and reporting frequency.
- **Telemetry spoofing** and **extreme telemetry** test whether correctly formatted but false or implausible vitals are accepted.
- **Malformed telemetry** tests how the receiving path handles incomplete or invalid payloads.
- **Replay** tests whether previously valid patient telemetry can be presented as though it were current.
- **Scenario-focused safety cases** include critical vitals, suppressed fall or panic alerts, and falsely normal battery state.

The implemented activities focus on how patient telemetry can become false, stale, malformed, inconsistent or difficult to trust.

MEDICAL IOT SECURITY-TO-SAFETY ESCALATION



- The activity does not directly harm the patient.
- Harm becomes possible because untrusted telemetry changes the **clinical representation**.
- The evidence chain links packet contents, gateway logs, dashboard state and hazard analysis notes.

The escalation point is reached when untrusted data is allowed to influence a safety-relevant clinical interpretation.

MITIGATION AND RESILIENCE FOR MEDICAL IOT

- Authenticate gateways and publishers before accepting patient telemetry.
- Protect MQTT communication where patient data or operational state is exposed.
- Validate vital signs using **range checks**, **rate-of-change checks** and consistency checks between fields.
- Detect **missing**, **stale**, **duplicated** and **malformed** telemetry explicitly.
- Correlate unsafe readings with alert or status fields rather than trusting each field independently.
- Provide visible degraded-state indicators when current patient telemetry cannot be trusted.

A safe monitoring system must recognise when the patient representation is incomplete, stale or inconsistent.

Smart Building Case Study

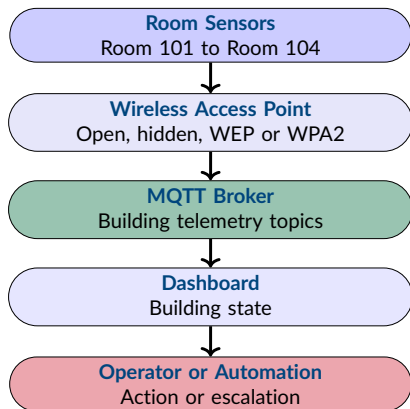
SISEN Scenario Context

The Smart Building scenario uses wireless room or zone sensors, an access point, MQTT telemetry and a dashboard to monitor environmental and occupancy-related state.

- The launcher supports open, hidden, WEP and WPA2 modes, together with a Smart Building MAC-filtering example activity.
- Sensor telemetry may include environmental state such as temperature, humidity, CO₂ or occupancy indicators.
- Students observe normal telemetry, capture traffic, trigger bounded activities and analyse safety relevance.
- The key safety question is whether building state remains **accurate**, **timely** and **available** for monitoring or automation.

Automation may respond correctly to the displayed data while still being unsafe

SMART BUILDING SYSTEM ARCHITECTURE



- The access point is both a communication dependency and a security boundary.
- MQTT exposes the application-level representation of each room or zone.
- A loss affecting one room is different from a sensor-layer blackout affecting all rooms.
- Wireless evidence and MQTT evidence help locate the affected layer.

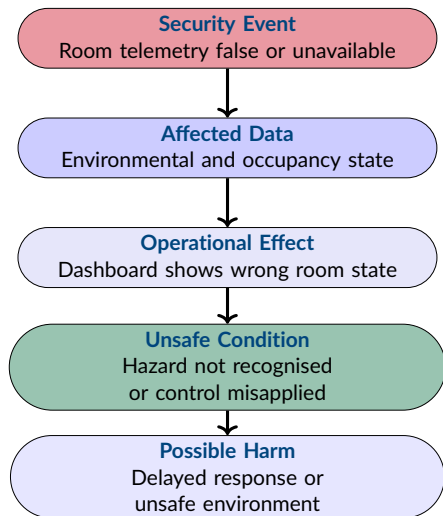
A building may appear operational while one room, one wireless mode, or the complete sensor layer is no longer trustworthy.

SMART BUILDING ACTIVITIES IMPLEMENTED IN SISEN

- **Wireless and MQTT observation** establish the normal traffic pattern and exposed metadata.
- **Telemetry spoofing, extreme values, replay** and **telemetry noise** test source trust, integrity, freshness and availability.
- **Single-client disconnection** interrupts one room while other rooms continue reporting.
- **Sensor blackout** interrupts all active room sensors while scenario infrastructure remains running.
- Separate **HW-AP activities** include hidden SSID observation, MAC spoofing, WEP IV collection, WPA2 handshake capture and bounded deauthentication. These are documented under `ap/hw-ap/docs/` and are not launched through the main scenario launcher.

The same dashboard symptom may result from application-layer injection, wireless disruption or infrastructure-level failure.

SMART BUILDING SECURITY-TO-SAFETY ESCALATION



- A single-client loss creates a local blind spot.
- A sensor blackout creates a wider loss of environmental visibility.
- Spoofed or extreme telemetry may create false reassurance or inappropriate response.

The safety question is whether the building system knows when its view of the environment can no longer be trusted.

MITIGATION AND RESILIENCE FOR SMART BUILDINGS

- Use stronger wireless protection and avoid treating hidden SSIDs or MAC filtering as security controls.
- Authenticate publishers and restrict MQTT topic access.
- Validate room telemetry using value ranges, timing checks, freshness checks and cross-sensor consistency.
- Mark retained values as stale when telemetry stops.
- Distinguish **one-room loss** from **complete sensor blackout** in the dashboard and logs.
- Provide fail-safe or degraded operation when automation cannot establish current room state.

Resilience depends on detecting both false data and absence of data before automation or operators act on it.

6LoWPAN Case Study

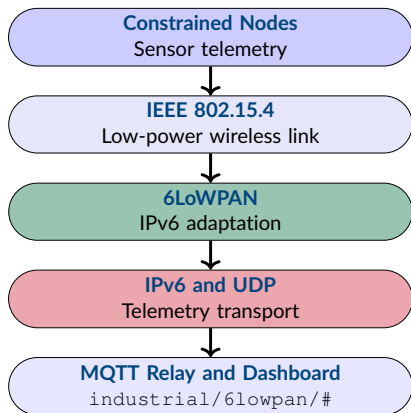
SISEN Scenario Context

The 6LoWPAN scenario uses constrained wireless nodes, IEEE 802.15.4, 6LoWPAN adaptation, IPv6 and UDP telemetry, with relay into MQTT under `industrial/6lowpan/#`. With four active nodes, the assets are the Boiler Room, Process Line, Cold Storage and Loading Bay.

- Constrained nodes represent low-power sensing devices with limited communication and processing resources.
- IEEE 802.15.4 and 6LoWPAN provide the low-power network path.
- Students can capture both **wpan** and **lowpan** views of the same communication path.
- Safety depends on telemetry being current, complete and correctly interpreted despite constrained networking.

A constrained sensor network can fail silently from the perspective of a

6LoWPAN SYSTEM ARCHITECTURE



- The same telemetry can be inspected at the 802.15.4, 6LoWPAN, IPv6/UDP and MQTT-facing stages.
- UDP telemetry provides low overhead but requires separate thinking about identity, integrity and freshness.
- The MQTT relay makes constrained telemetry visible to conventional monitoring tools.
- Layered capture helps identify where loss, delay or manipulation begins.

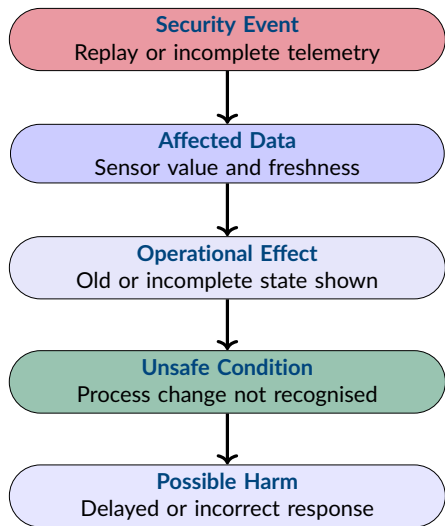
Trust in the dashboard depends on every adaptation and forwarding stage between the constrained node and the monitoring view.

6LoWPAN ACTIVITIES IMPLEMENTED IN SISEN

- **Wireless and protocol capture** records IEEE 802.15.4 and 6LoWPAN traffic using `wpan1` and `lowpan0` views.
- **MQTT topic observation** shows the relayed constrained telemetry under `industrial/6lowpan/#`.
- General **protocol-path attacks** include spoofed, extreme, replayed, malformed and incomplete telemetry injected through the active namespace path.
- **Replay and freshness** demonstrate how an old but plausible value may be treated as current.
- **Missing-field activity** shows that a packet may be delivered successfully while the application payload remains incomplete.
- **Scenario-focused safety cases** include masked boiler pressure, hidden emergency-stop state and hidden machine-overheat state.

In constrained systems, replay, incomplete payloads and delayed recognition may be as important as obvious packet-level failure.

6LoWPAN SECURITY-TO-SAFETY ESCALATION



- The repeated message may be syntactically valid and even plausible.
- The safety problem is that it no longer represents the current physical or operational condition.
- Incomplete telemetry may omit a field required to establish the current safety-relevant state.

Freshness is a security property and a safety dependency in time-sensitive constrained monitoring.

MITIGATION AND RESILIENCE FOR 6LoWPAN

- Apply message authentication and source validation appropriate to constrained nodes.
- Use sequence numbers, timestamps, expiry checks or duplicate detection to establish freshness.
- Detect missing telemetry and mark retained values as stale.
- Validate constrained telemetry against physical ranges and expected rates of change.
- Monitor 802.15.4, 6LoWPAN, UDP and MQTT evidence to localise failure.
- Provide degraded operation when the current constrained network state cannot be established confidently.

A resilient 6LoWPAN deployment must reason about timeliness, loss and forwarding confidence, not only packet format.

Comparing the Applied Cases

COMPARING THE THREE SISEN SCENARIOS

Scenario	Main Evidence	Security Failure	Safety-Relevant Effect
Medical IoT	Gateway log, MQTT capture, dashboard	False, malformed, noisy or masked vitals	Incorrect clinical representation
Smart Building	Wireless capture, MQTT capture, dashboard	Spoofing, client loss, blackout or wireless infrastructure weakness	Incorrect or incomplete building state
6LoWPAN	wpan, lowpan, UDP and MQTT evidence	Replay, missing telemetry, spoofing or extreme values	Loss of timely operational awareness

The scenarios differ technically, but all require evidence-based reasoning from security event to system behaviour and safety consequence.

COMMON SECURITY-INFORMED SAFETY PATTERNS

- **Data trust** depends on identity, integrity, freshness and plausibility.
- **Availability failures** may appear as retained values rather than obvious alarms.
- **Layered evidence** is needed to distinguish wireless, protocol, gateway, broker and dashboard effects.
- **Bounded activities** are useful because they produce repeatable evidence without uncontrolled disruption.
- **Safety analysis** must consider how operators or automation interpret the displayed state.

A safe system should not only resist attacks; it should recognise when its evidence is no longer good enough for safe operation.

APPLYING SISEN IN PRACTICE

- Start with the relevant scenario guide and confirm normal telemetry.
- Use the SISEN Attack and Disruption Guide to run one bounded helper activity at a time, or follow `docs/manual-attacks.md` for manual infrastructure activities.
- Capture traffic or logs before, during and after the activity.
- Identify the affected component, trust boundary and observable system effect.
- Complete the SISEN Hazard Analysis and Evidence Sheet using precise evidence references from the dashboard, packet capture, MQTT output and terminal logs.
- Link each mitigation to the specific weakness or unsafe behaviour observed, state how its effectiveness would be demonstrated, and identify the residual risk.

The practical objective is not to run attacks in isolation, but to explain what the evidence says about safety-relevant system behaviour.

- Lecture 8 applies security-informed safety reasoning to the three implemented SISEN scenarios.
- Medical IoT focuses on patient telemetry, gateway forwarding and clinical interpretation.
- Smart Building focuses on wireless access points, room sensors, MQTT telemetry and building state.
- 6LoWPAN focuses on constrained nodes, low-power wireless capture, UDP telemetry and MQTT relay.
- Across all scenarios, the same question is whether the displayed state remains trustworthy enough for safe decisions.
- Evidence capture, bounded activities and the SISEN Hazard Analysis and Evidence Sheet connect technical observations to safety consequences, assurance evidence and residual risk.

KEY REFERENCES

- NIST. (2021). *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach*. NIST SP 800-160 Vol. 2 Rev. 1. [\[Link\]](#)
- FDA. *Cybersecurity in Medical Devices*. [\[Link\]](#)
- NCSC. *Operational Technology Guidance*. [\[Link\]](#)
- OASIS. *MQTT Version 5.0*. [\[Link\]](#)
- IETF. *IPv6 over Low-Power Wireless Personal Area Networks*. [\[Link\]](#)